DOC 14 · CAPATAZ AI

Seguridad, privacidad y confidencialidad

Blindaje operativo del MVP para scoring, auditoría y futura evolución sensible

Este documento define qué datos existen, qué datos todavía no deben entrar, cómo se gobierna el acceso por rol y negocio, cómo se protegen secretos, cómo se audita el sistema y por qué las demos no pueden jugar con datos reales sin permiso.

Salida esperada: perímetro de seguridad + política de datos + auditoría + separación de entornos + regla de demos seguras

Capataz opera con personas, score y evidencia. La frontera correcta es: mínimo dato, máximo control y cero improvisación con secretos.

Lectura ejecutiva del documento 14

Tema	Definición	Decisión de alto impacto
Objetivo	Blindar el MVP operativo sin convertirlo prematuramente en un banco.	Seguridad proporcional, seria y ejecutable.
Alcance	Dashboard, tareas, score, alertas, reportes, configuración y futuro camino a fintech.	Todo lo sensible entra con límites explícitos.
Modelo de acceso	Rol + workspace + ownership + servidor.	No se confía en el frontend.
Regla de demos	Sin permiso explícito no se usan datos reales.	Mock o anonimización por default.
Gobierno	Auditoría, backups, segregación de entornos y secretos fuera del repo.	Trazabilidad desde el día uno.

1. Tesis del documento

Capataz no puede nacer con una puerta blindada al frente y cartón por detrás. Este documento fija el perímetro mínimo de seguridad, privacidad y confidencialidad del MVP para que producto, ingeniería, operación y dirección sepan exactamente qué datos existen, quién puede verlos, dónde viven y qué prácticas quedan prohibidas desde el día uno.

El objetivo no es sobrediseñar un banco en la fase inicial. El objetivo es construir un sistema de operación serio, auditable y preparado para evolucionar a capas más sensibles sin reescribir la base.

> Decisión base: Capataz se diseña para operar con datos reales mínimos, controlados y auditables. Cualquier expansión a datos más sensibles exige rediseño explícito.

2. Principios rectores

Minimización: solo almacenamos lo necesario para operar dashboard, tareas, score, alertas, reportes y configuración.

- Separación por negocio: cada workspace o negocio tiene aislamiento lógico estricto y políticas de acceso por rol + ownership + tenant.
- Servidor como fuente de verdad: permisos, cálculo de score, auditoría y exportación viven del lado servidor; el frontend no define seguridad.
- Trazabilidad: toda acción crítica debe dejar huella auditable con actor, entidad, timestamp, workspace y resultado.
- Entornos segregados: desarrollo, preview, staging y producción no comparten secretos ni datos sin sanitización.
- Demo responsable: no se usan datos reales en demos, videos o ambientes de prueba sin autorización explícita.

> Regla transversal: el frontend representa permisos; el backend y la base de datos los hacen cumplir.

3. Qué datos sí va a almacenar el MVP

El MVP de Capataz sí necesita almacenar datos operativos reales. La clave no es fingir que no existen, sino clasificarlos bien y limitar su exposición.

Categoría	Datos mínimos	Propósito	Clasificación
Identidad y acceso	workspace_id, user_id, nombre laboral, correo, rol, estado de usuario, timestamps, identificadores del tenant	Operación del sistema y autorización por rol / tenant	Restringido
Sesión y auth	tokens de sesión administrados por el proveedor de auth, claims de rol, trazas técnicas de inicio/cierre de sesión	Autenticación y validación de acceso	Restringido
Usuarios operativos	nombre visible, avatar	Asignación de tareas,	Restringido

	opcional, supervisor asignado, equipo, puesto funcional, zona / negocio si aplica	score y visibilidad	
Tareas	título, descripción, prioridad, estatus, fechas, responsable, etiquetas, board_id, columna, historial de cambios	Gestión operativa diaria	Restringido
Checklists	plantilla, ítems, estado de cada ítem, progreso, timestamps, responsable del cambio	Bloqueo de cierre y evidencia operativa	Restringido
Score	score total, factores compliance/speed/consistency/activity, snapshots y ventanas de cálculo	Ranking operativo y evolución a analítica / fintech	Restringido
Alertas	tipo, severidad, estado de lectura por usuario, entidad relacionada, fecha de generación	Seguimiento de urgencias y eventos críticos	Restringido
Reportes	filtros usados, fecha de generación, formato de exporte, referencia al archivo generado	Analítica y exportación controlada	Interno
Configuración	columnas Kanban, parámetros de score MVP, catálogos, preferencias del workspace	Gobierno del producto	Restringido
Auditoría y observabilidad	trace_id, actor, acción, resultado, metadatos del recurso, IP / user-agent cuando aplique, errores	Investigación, soporte y cumplimiento interno	Crítico

La recomendación para el MVP es no meter campos 'por si luego sirven'. Todo dato debe justificar su existencia en una pantalla, regla o reporte real.

4. Qué datos sensibles no va a almacenar todavía

Esto es una frontera explícita. Si en algún momento negocio quiere cruzarla, se requiere nuevo ADR, revisión legal, actualización del documento y rediseño de controles.

Dato no almacenado aún	Razón / decisión
Contraseñas en texto plano	La autenticación se delega a Supabase Auth / proveedor equivalente; no se guarda ningún secreto de usuario en claro.
Datos bancarios o fintech productivos	No se almacenan CLABE, números de cuenta, PAN, CVV, wallets ni saldos durante el MVP.
Nómina y compensación	No se guardan sueldos, bonos, incidencias de nómina ni dispersión bancaria en esta fase.
Documentos oficiales	No se almacenan INE, pasaporte, NSS, CURP, RFC, comprobantes o expedientes laborales salvo requisito legal explícito posterior.
Biometría o salud	No se almacenan huellas, rostro, voz, historial médico, discapacidad o datos de bienestar.
Geolocalización precisa	No se guarda ubicación continua ni coordenadas precisas del empleado.
Mensajería personal o contactos	No se copian agendas, contactos personales ni historiales de chat externos.
Contenido real de WhatsApp futuro	La futura integración multicanal no debe iniciar guardando conversaciones completas; en MVP solo existe concepto / mock.

5. Clasificación de la información

Capataz debe hablar un lenguaje de clasificación sencillo para evitar el clásico desastre de tratar todo como trivial o todo como ultrasecreto.

Nivel	Qué incluye	Tratamiento	Ejemplos
Público	nada operativo sensible; material comercial autorizado	puede mostrarse en marketing o demo pública con aprobación	landing, mockups ficticios
Interno	metadatos generales no personales o reportes agregados	solo personal interno y stakeholders autorizados	conteos globales, catálogos
Restringido	datos de usuarios, tareas, score, alertas, configuración	solo por rol, tenant y necesidad operativa	boards, score individual, checklists
Crítico	audit logs, service roles, exports sensibles, backups	acceso mínimo, solo server / admins autorizados	service keys, backups, auditoría

6. Roles, permisos y acceso por negocio

El acceso se resuelve por cuatro llaves al mismo tiempo: identidad, rol, workspace y ownership. Tener sesión no equivale a tener permiso.

Todo recurso del dominio debe pertenecer a un workspace. Toda consulta, exportación, mutación o cálculo de score debe validar el tenant efectivo antes de responder.

Rol	Alcance visible	Acciones principales	Edita esquema
Administrador	todo el workspace	configuración, columnas, usuarios, reportes, score, auditoría operativa	sí

Gerente	unidad / negocio asignado	dashboard agregado, reportes, score agregado, seguimiento	no por default
Supervisor	equipo directo o área asignada	tareas, Kanban, checklists, score del equipo, alertas	sí con permiso
Operador / Empleado	lo propio	sus tareas, checklists, alertas y score propio	no
Soporte interno temporal	caso acotado y por tiempo limitado	solo bajo ticket, aprobación y trazabilidad	no

- Todo query debe resolverse dentro del workspace efectivo.
- Todo exporte respeta tenant + rol + ownership.
- Los IDs globales no bastan para autorizar acceso; siempre se valida pertenencia al negocio.

7. Protección de secretos y credenciales

Los secretos viven fuera del repositorio y fuera del cliente. Se gestionan como variables de entorno seguras en Vercel, Supabase y herramientas de CI/CD. Las llaves con privilegio alto, como service role o tokens de integraciones futuras, solo pueden existir del lado servidor.

- Reglas obligatorias:
- No subir `.env` al repositorio.
- No exponer service keys en bundles del frontend, screenshots, logs o documentación compartida con cliente.
- Separar secretos por ambiente: `dev`, `preview`, `staging` y `prod`.
- Rotación inmediata si un secreto aparece en commit, consola compartida o incidente.
- Uso de cuentas nominales, no cuentas compartidas, para paneles administrativos y proveedores.

Checklist obligatorio de ingeniería: service role solo en server, jamás en cliente; secretos separados por ambiente; rotación inmediata ante fuga o sospecha de fuga.

8. Logs de auditoría y trazabilidad

Capataz debe poder responder preguntas incómodas sin improvisar: quién vio esto, quién lo cambió, cuándo se recalculó el score, por qué apareció esta alerta, quién exportó tal reporte.

Los logs de auditoría no son decoración. Son parte del producto.

Evento auditado	Qué se registra	Objetivo
Login / logout y fallos de auth	quién intentó entrar, cuándo y con qué resultado	seguridad + soporte
Creación / edición / cierre de tareas	actor, tarea, cambios clave, trace_id	operación + auditoría

Cambios de score o recálculos	trigger, ventana, factores, resultado	explicabilidad
Lectura / exportación de reportes	quién exportó, rango, formato, volumen	control de datos
Cambios de configuración	board schema, roles, parámetros	gobierno del sistema
Accesos denegados	rol, recurso, motivo	detección de abuso o mala configuración
Errores críticos	trace_id, módulo, stack resumido, severidad	observabilidad

9. Política de acceso interno

El acceso interno a producción se concede por necesidad real y por tiempo limitado.

- Reglas mínimas:
- Menor privilegio por default.
- Acceso nominal y trazable; nada de usuarios genéricos compartidos.
- Las tareas de soporte deben ir respaldadas por ticket, incidente o solicitud aprobada.
- El acceso de lectura se prefiere sobre acceso de escritura.
- El acceso temporal elevado debe tener caducidad y responsable aprobador.
- Desarrolladores no deben consultar datos reales de clientes por curiosidad, conveniencia o debugging informal.

10. Entornos: dev vs prod

Capataz no debe vivir en un pantano de ambientes mezclados. La contaminación entre entornos es uno de los caminos más rápidos al incidente.

Ambiente	Datos permitidos	Secretos	Regla
Desarrollo local	mocks, seed sintético o datos anonimizados	llaves de dev	nunca se conecta con service role de producción
Preview / Vercel PR	datos de prueba, staging o snapshot sanitizado	llaves separadas por preview/staging	ideal para QA visual y UAT controlado
Staging	copia funcional sin PII real o con datos aprobados y enmascarados	secretos propios de staging	pruebas integrales antes de prod
Producción	datos operativos reales autorizados	secretos exclusivos de prod	acceso restringido y auditado

11. Manejo de backups y recuperación

Los backups deben existir, estar cifrados, tener retención conocida y haber sido probados. Un backup que nunca se restaura es una promesa decorativa.

- Base mínima recomendada para el MVP:
- Respaldos automáticos de base de datos con retención definida por el proveedor.
- Exportes y artefactos críticos almacenados en buckets con control de acceso.
- Prueba periódica de restauración en ambiente aislado.
- Registro de fecha del último backup exitoso y del último restore drill.
- Objetivos operativos iniciales sugeridos: RPO de hasta 24 horas y RTO de hasta 8 horas para el MVP, endureciendo después si negocio lo requiere.

MVP recomendado: backups automáticos + restore drill trimestral + retención conocida + acceso muy restringido al material de recuperación.

12. Política de demos, QA y materiales compartidos

La regla madre es simple: si no hay permiso explícito, no se usan datos reales.

- Aplicación práctica:
- Las demos comerciales usan seed data ficticia o anonimizaciones irreversibles.
- Las capturas, videos y decks no muestran nombres reales, correos, score real ni tareas reales sin autorización escrita.

- Para QA, se prefieren workspaces sandbox con usuarios sintéticos.
- Si un cliente autoriza demo con datos reales, se documenta alcance, duración y quién puede verla.

Política innegociable: ningún video, captura o demo comercial debe exponer nombre real, correo real, score real o tareas reales sin autorización escrita.

13. Línea roja para la evolución futura a fintech

El score puede ser semilla de futuros productos más sensibles, pero el salto no se hace por entusiasmo. Se hace con controles nuevos, revisión legal y rediseño consciente.

Etapa	Qué exige	Estado
MVP actual	aislamiento por workspace, auth seria, RLS, auditoría, backups, política de demos	suficiente para operación controlada
Antes de evolución fintech	revisión legal, mapa de datos ampliado, hardening de IAM, DPA, política de retención, clasificación extendida	obligatorio antes de manejar datos financieros reales
Antes de producción financiera sensible	pentest, monitoreo más profundo, gestión formal de incidentes, cifrado y llaves más robustas, evaluación de terceros	ya no es opcional

14. Definición de terminado

- Existe inventario explícito de datos almacenados y no almacenados.
- Quedan definidos roles, acceso por negocio, secretos, auditoría, entornos, backups y política de demos.
- El documento sirve como baseline para producto, frontend, backend, QA y dirección.
- Cualquier nueva categoría de dato sensible dispara revisión de este documento antes de entrar al backlog de implementación.